



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

2 - “Overview: Main Concepts and Terminology” *[Chapter 1]*

Gabriele D'Angelo <g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

Outline



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Computer Security **Concepts**
- **Threats, Attacks, and Assets**
- Fundamental Security **Design Principles**
- **Attack Surfaces and Attack Trees**
- Computer Security **Strategy**

Fundamental Questions



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The focus is on three **fundamental questions**:
 - **what assets** do we need to **protect**?
 - **how** are those assets **threatened**?
 - **what** can we do to **counter those threats**?

Threat Model



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- In cybersecurity, a **threat model** is a **structured way of identifying potential threats, vulnerabilities, and risks** to a system, application, or organization. It is a **systematic approach to understanding the possible attack vectors, threat actors, and the potential impact** of successful attacks. (definition provided by “claude.ai”, 04/03/2024)

Computer Security (NIST definition)



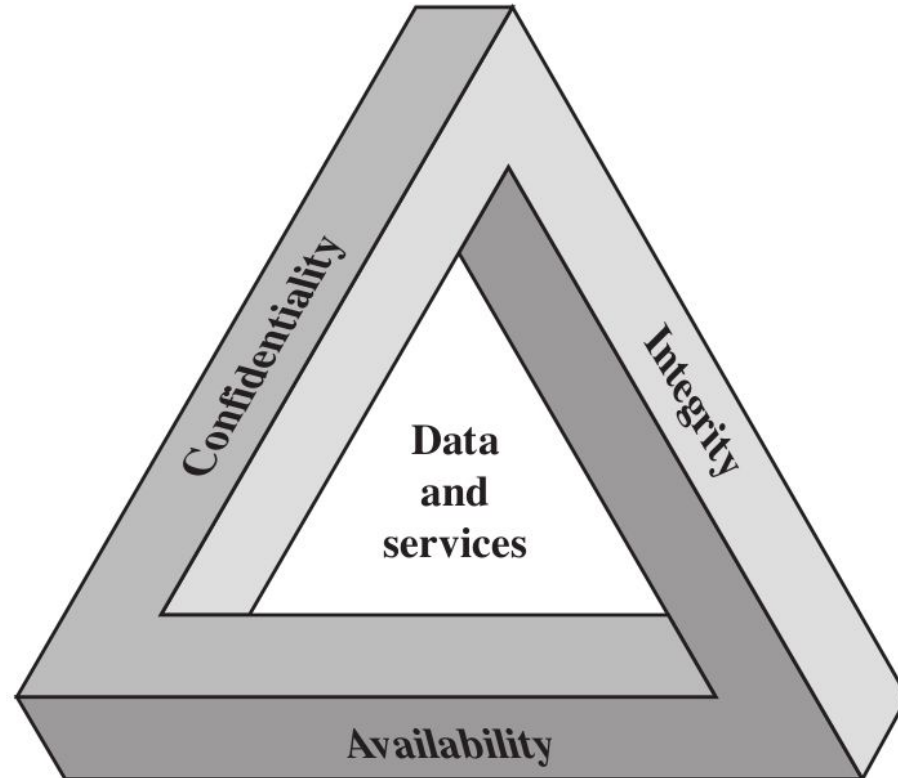
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- «The protection afforded to an automated information system in order to attain the applicable objectives of preserving the **integrity**, **availability** and **confidentiality** of information system resources.»
- It includes hardware, software, firmware, information/data, and telecommunications

The Security Requirements “CIA” Triad



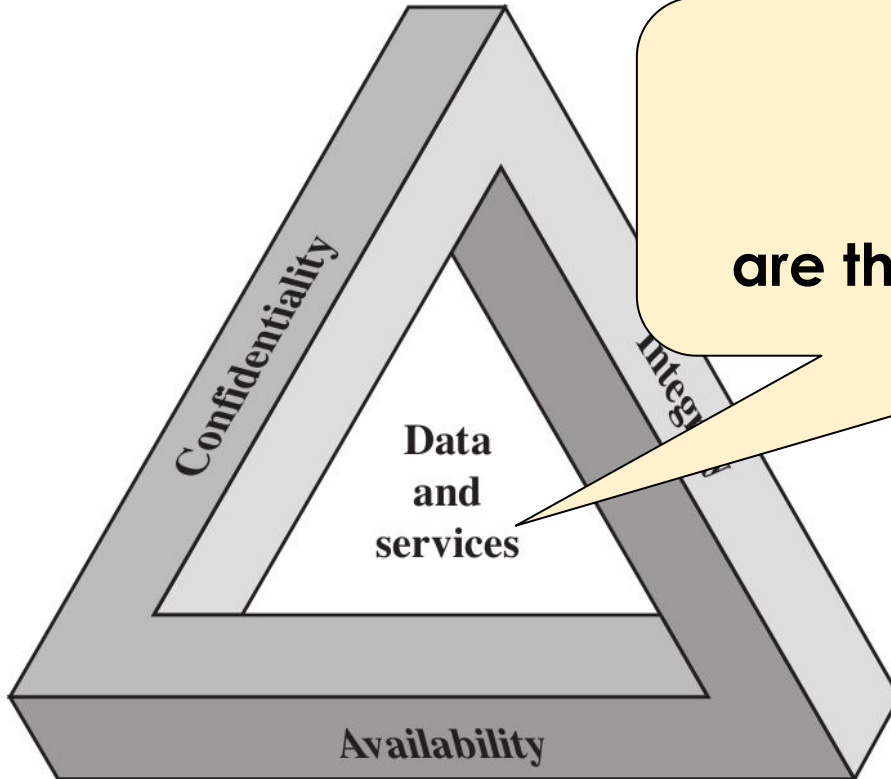
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

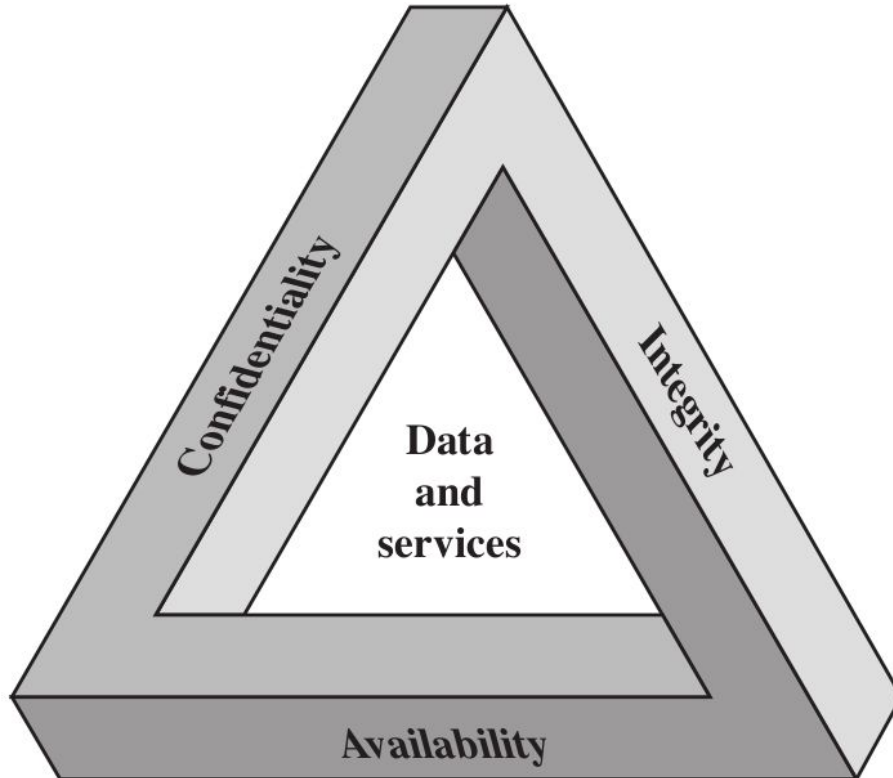


In this approach
“**data** and **services**”
are the core elements to protect

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



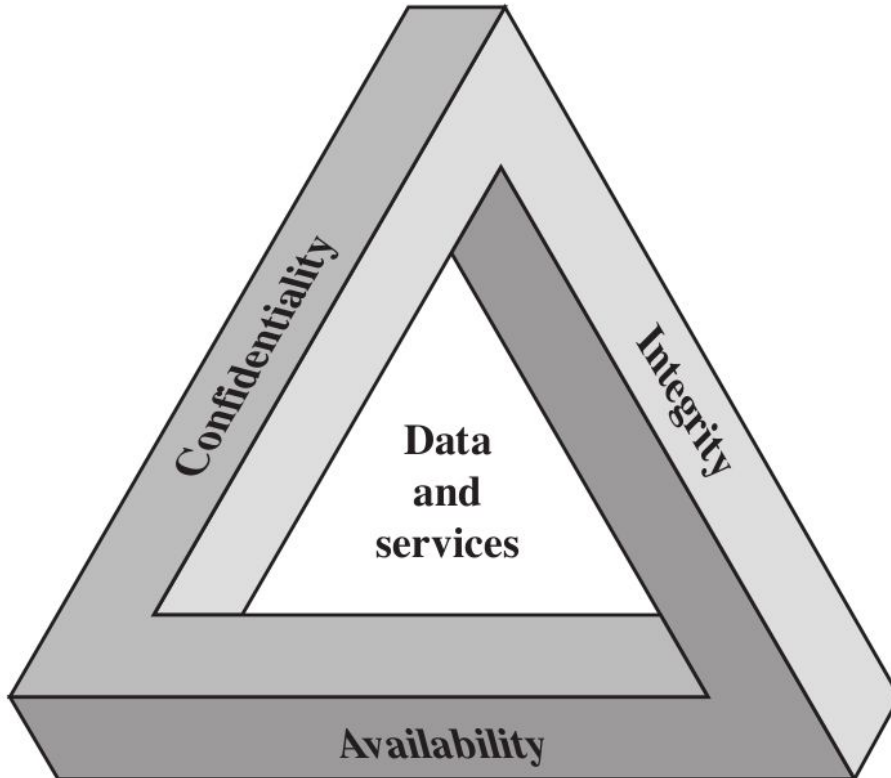
confidentiality

- data confidentiality
- privacy

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

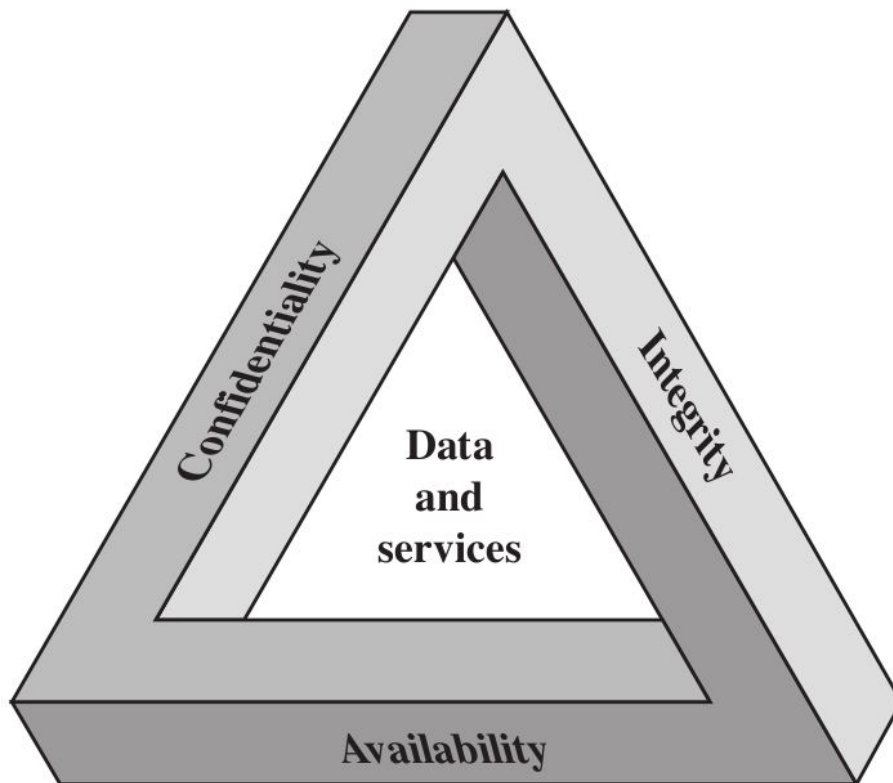
data confidentiality

private or **confidential**
information is not made
available or disclosed
to unauthorized individuals

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

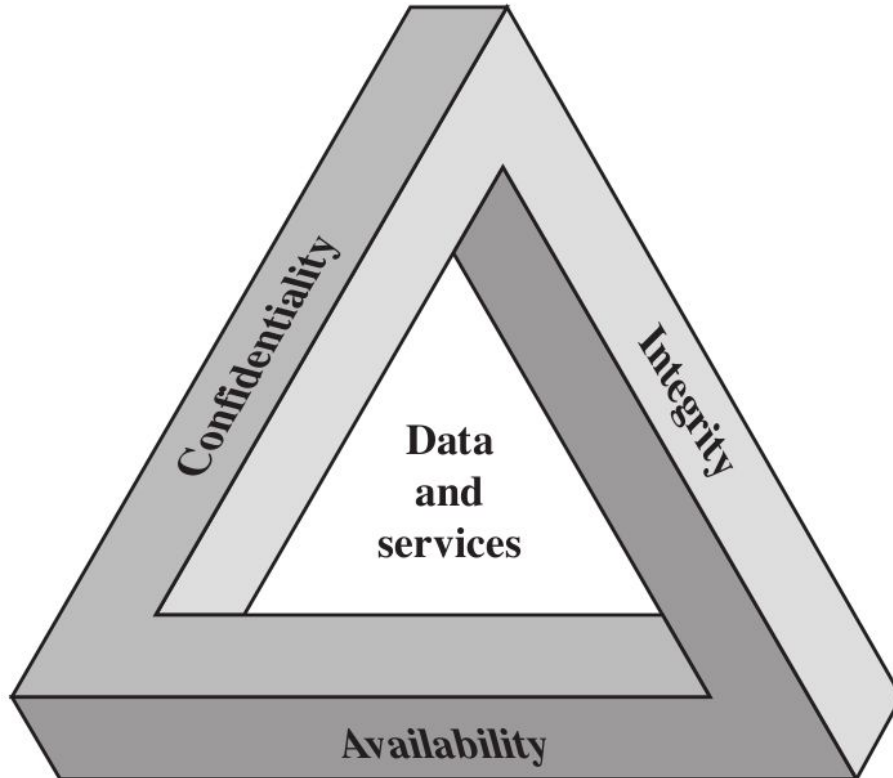
privacy

individuals control what information related to them may be **collected** and **stored**, by whom and to whom this information may be **disclosed**

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

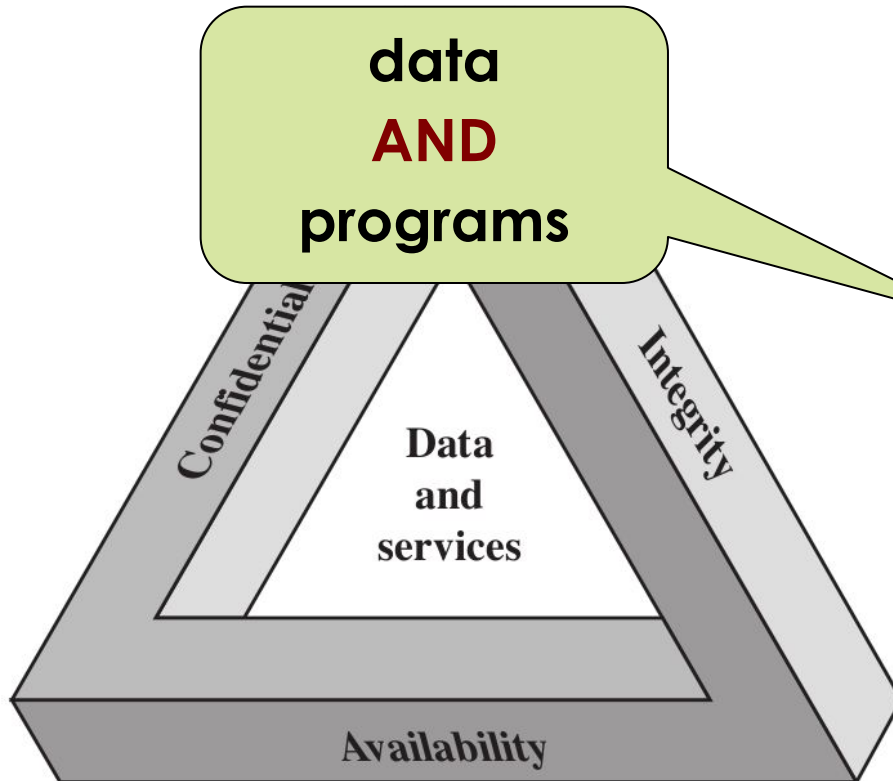
integrity

- data integrity
- system integrity

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

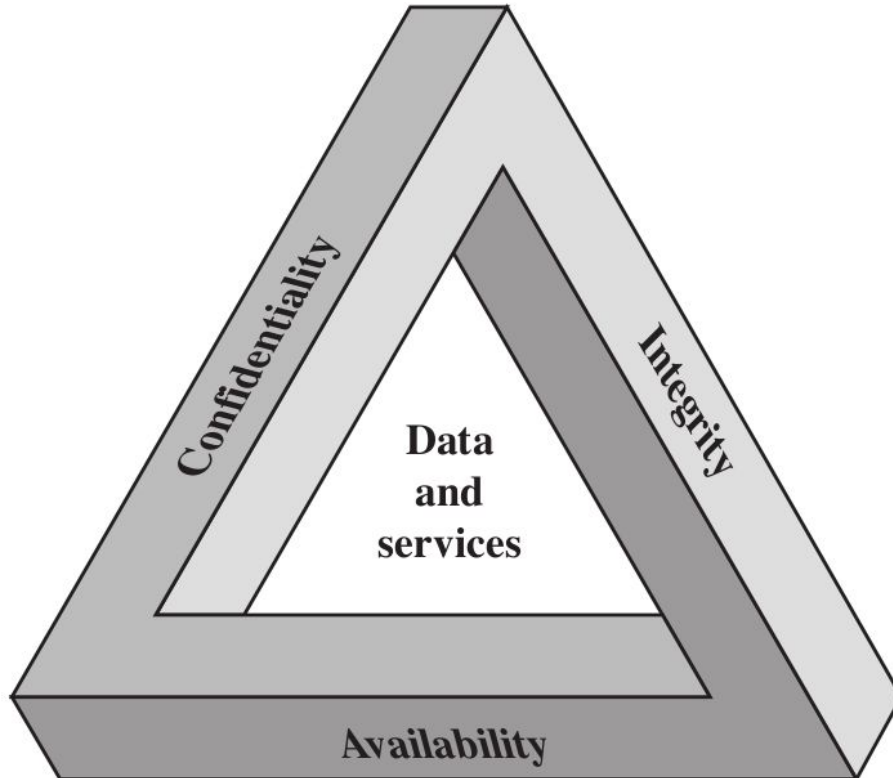
integrity

- data integrity
- system integrity

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

integrity

- data integrity
- system integrity

availability

- data availability
- services availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Preserving authorized restrictions on **information access** and **disclosure**
- Including means for protecting personal **privacy** and proprietary information

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Guarding against improper **information modification** or **destruction**
- Including ensuring information **non-repudiation** and **authenticity**

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

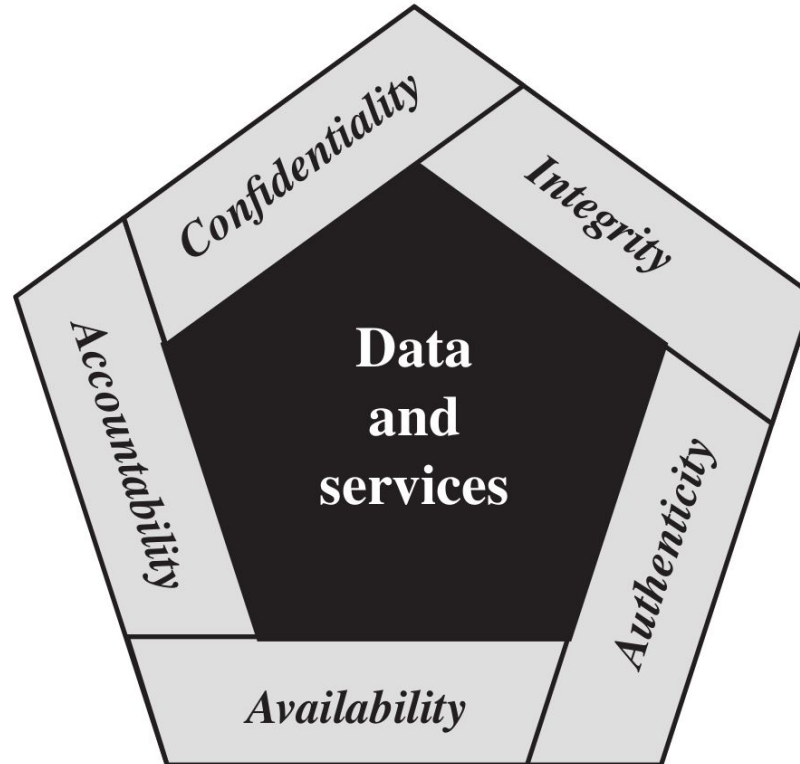
Availability

- Ensuring **timely** and **reliable access** to and use of **data** (and **services**)

The Security Requirements



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Accountability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

- Property of being **genuine** and being able to be **verified** and **trusted**
- For example: *confidence in the validity* of a **transmission**, a **message**, or a message **originator**

Accountability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Accountability

- The requirement for **actions of an entity** to be **traced uniquely to that entity**
- **For example:** *ability to find the originator of a **transmission**, a **message**, or an action*

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Necessary to support
non-repudiation, deterrence,
fault isolation, intrusion
detection and prevention...
recovery and legal action

Accountability

The requirement for **actions of an entity** to be **traced uniquely to that entity**

- For example: *ability to find the originator of a **transmission**, a **message**, or an action*

Level of Impact



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Low

The loss could be expected to have a **limited adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Moderate

The loss could be expected to have a **serious adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

High

The loss could be expected to have a **severe or catastrophic adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Computer security is **not as simple as it might first appear to the novice**
- **Potential attacks** on the security features must be considered
- Procedures used to provide particular services are **often counterintuitive**
- **Physical** and **logical placement** needs to be determined
- **Multiple algorithms** or **protocols** may be involved

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attackers** only need to find a **single weakness**
- **Developers/administrators** need to find **all weaknesses**
- It is an **asymmetric game!** (*i.e. the players do not stand on equal ground*)
- The attacker can **combine multiple weaknesses**

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Users** and **system managers** tend to **not see the benefits** of security
until a failure occurs
 - **good security** is **invisible**
 - **bad security** is **visible only after a security incident**
 - (usually) **good security does not generate revenues** (*i.e. if compared with advertisements, marketing etc.*)

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Security requires **regular and constant monitoring** (*i.e. security is a process and not a product*)... **security is costly!**
- It's often an **afterthought** to be incorporated into a system **after the design is complete** (*i.e. the Internet*)
- Thought of as an **impediment** to **efficient** and **user-friendly operation**...
(again) **security is a cost!**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Adversary (threat agent)**: an **entity** that **attacks**, or is a **threat** to, a system
- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate the security policy of a system**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Adversary (threat agent)**: an entity that poses a **threat** to, a system
- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**





In some cases the threat is not much “intelligent”

Example: some (*not all*) Denial of Service attacks
are rather **simple** (or stupid)

or is a **threat** to, a

- **Attack:** an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Countermeasure**: an **action, device, procedure, or technique** that **reduces a threat, a vulnerability, or an attack** by **eliminating** or **preventing** it, by **minimizing** the **harm it can cause**, or by discovering and reporting it so that **corrective actions can be taken**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Risk**: an **expectation of loss** expressed as the **probability** that a **particular threat** will exploit a **particular vulnerability** with a **particular harmful result**

Impact	Likelihood				
	Rare	Unlikely	Possible	Likely	Almost certain
Catastrophic	moderate	moderate	high	critical	critical
Major	low	moderate	moderate	high	critical
Moderate	low	moderate	moderate	moderate	high
Minor	very low	low	moderate	moderate	moderate
Insignificant	very low	very low	low	low	moderate

**RISK
MATRIX**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Security policy**: a **set of rules and practices** that specify **how a system or organization provides security services** (*to protect sensitive and critical system resources*)

Example: the **password policy** (i.e. strong passwords and their expiration) of an organization is part of its **security policy**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **System resource (asset)**: **data**; a **service** provided by a system; a **system capability**; an **item** of **system equipment**; a **facility** that houses system operations and equipment
- **Threat**: a **potential for violation of security**, which exists when there is a circumstance, capability, action, or event that could **breach security** and **cause harm**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

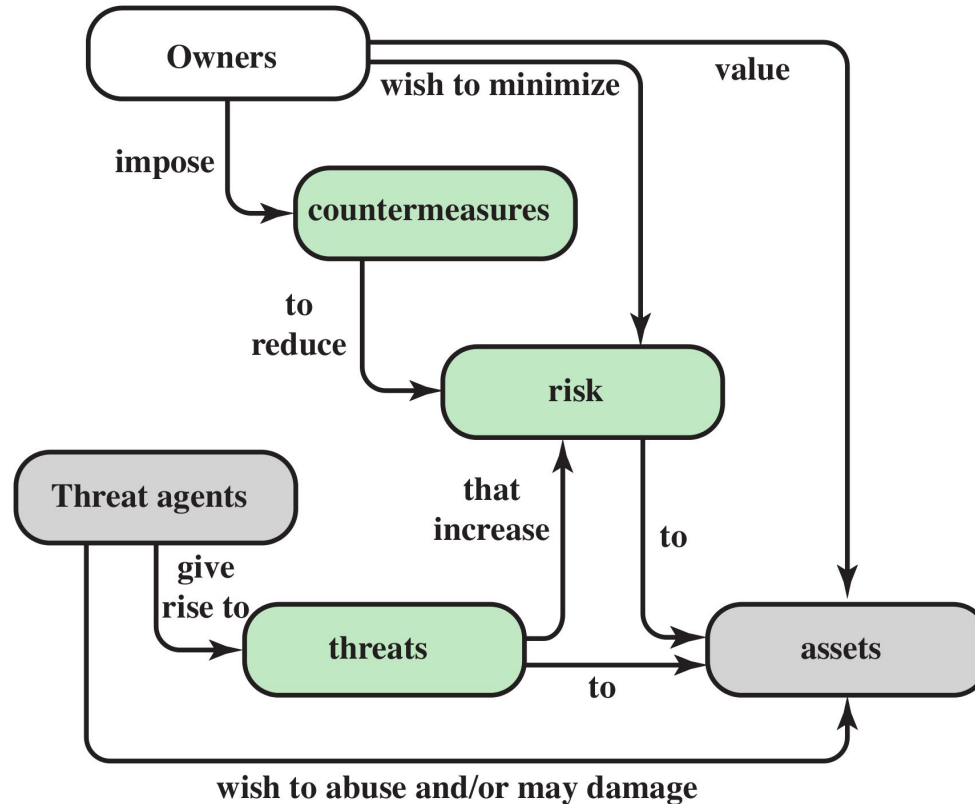
- **Vulnerability**: a **flaw** or **weakness** in a system's **design, implementation, or operation** and **management** that could be **exploited** to **violate the system's security policy**

Example: *there is a vulnerability in the **software** or the **users** are **not properly educated** to deal with email phishing*

Security Concepts and Relationship



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Vulnerability** (of system resources):
 - **corrupted** (loss of **integrity**)
 - **leaky** (loss of **confidentiality**)
 - **unavailable** or very slow / **unresponsive** (loss of **availability**)

Vulnerabilities, **Threats** and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Threats:**
 - capable of **exploiting vulnerabilities**
 - represent a **potential security harm**

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attacks** (threats carried out):
 - **active** - attempt to **alter/affect** the **system resources**
 - **passive** – does **not** (directly) **affect** the **system resources**
 - **insider** or **outsider** (is it from an **internal** or **external thread**?)

More info about **active** and **passive** attacks in the following...

- **Attacks** (threats)
 - **active** - attempt to **alter/affect** the **system resources**
 - **passive** – does **not** (directly) **affect** the **system resources**
 - **insider** or **outsider** (is it from an **internal** or **external thread**?)

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken **to deal with a security attack**
 - **prevent**
 - **detect**
 - **recover**

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

- detect

- recover

Is that **always** possible?

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

- detect

- recover

No! That's why **detection** and **recovery** are of main importance

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken **to deal with a security attack**
 - **prevent**
 - **detect**
 - **recover**

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- May **introduce new vulnerabilities**
- **Residual vulnerabilities** may **remain**
- The **goal** is to **minimize residual level of risk** to the assets
*(that is to implement some kind of **mitigation**)*

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Unauthorized disclosure** is a threat to **confidentiality**
 - **exposure**: *this can be **deliberate** or be the result of a human, hardware, or software **error***
 - **interception**: *unauthorized **access** to data*
 - **inference**: *e.g., traffic **analysis** or use of limited access to get detailed information*
 - **intrusion**: *unauthorized **access** to sensitive data*

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Deception** is a threat to either **system** or **data integrity**
 - **masquerade**: e.g., Trojan horse; or an attempt by an unauthorized user to gain **access** to a system **by posing as** an authorized user
 - **falsification**: the **alteration** or **replacement** of valid data or the **introduction** of false data
 - **repudiation**: an entity **deceives** another by falsely **denying responsibility** for an act

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Disruption** is a threat to **availability** or system **integrity**
 - **incapacitation**: a result of physical **destruction** of or **damage** to system hardware
 - **corruption**: system resources or services function in an **unintended** manner; **unauthorized** modification
 - **obstruction**: e.g. **overload** the system or interfere with communications

Threat Consequences



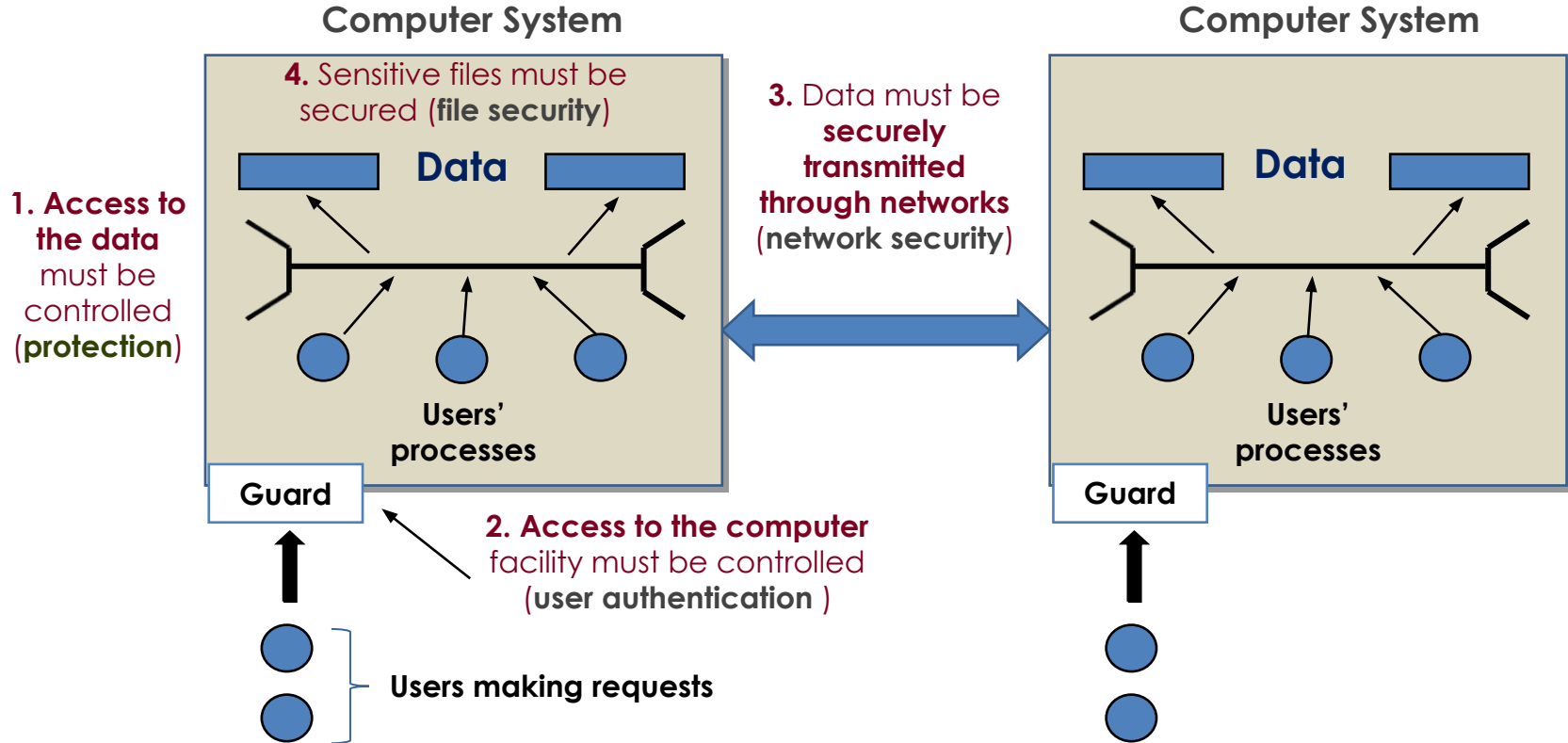
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Usurpation** is a threat to **system integrity**
 - **misappropriation**: *an entity assumes **unauthorized** logical or physical **control** of a system resource*
 - **misuse**: *causes a system component to perform a function or service that is **detrimental to system security***

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated



Example: the ATM skimmers



Integrity



A working program is modified to cause it to fail or to cause it to do some unintended task

Existing files are modified or new files are fabricated

Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	Or encrypted!	
Data	Files are deleted, denying access to users		
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Existing files are modified or new files are fabricated

Sco

Hardware

Software

Data

Communication

MA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

grity

program is
use it to fail or
to do some
ed taske modified or
fabricatede modified,
eordered,
lse messages
icated

Your personal files are encrypted!



Private key will be destroyed on
10/20/2013
12:37 PM

Time left
72 : 34 : 50

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To obtain the private key for this computer, which will automatically decrypt files, you need to pay **300 USD / 300 EUR** / similar amount in another currency.

Click «Next» to select the method of payment.

Any attempt to remove or damage this software will lead to the immediate destruction of the private key by server.

[Next >>](#)

Sco

Your personal files are encrypted!

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To decrypt files, you

immediate

Case Study: [WannaCry](#)

Private

Time left

72 : 34 : 50

Next >>

MA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

grity

program is
use it to fail or
to do some
ed task

modified or
fabricated

modified,
eordered,
lse messages
icated

Hardware

Software

Data

Communication

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, traffic **analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
BOLOGNA

The transmission is **intercepted**

- **Passive attacks** attempt to compromise the confidentiality of a system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, traffic **analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to intercept data from a system **but do not affect system**
 - **example:** eavesdropping
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

This happens when the message
is transmitted “**in clear**”
(**not encrypted**)



Even when the messages are encrypted
it is possible to perform some **analysis**

For example: content **size**, **frequency**...

- **difficult to detect**
- emphasis is on **prevention** rather than **detection**
- **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks** involve **modification** of the data stream (or the attacked system)
 - the **goal** is to **detect** them and to **recover**
 - four main types:
 - **masquerade**
 - **replay**
 - **modification of messages**
 - **denial of service**

Passive



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

One **entity** pretends to be a
different entity

Example: a **user** or a **device**

- **Active attacks**

attacked

or the

- the **goal** is to **steal** them and to **recover**

- four main types:

- masquerade
- replay
- modification of messages
- denial of service

Passive and Active

- **Active attacks** involve the attacker's interaction with the attacked system)

- the **goal** is to compromise the system
- four main types

- masquerade
- replay
- modification of messages
- denial of service

Passive capture of a data unit and its subsequent **retransmission** to produce an unauthorized effect:

Man-In-The-Middle (MITM) attack

Example: "Open sesame"

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked

- the s

- four main ty

- masquer

- replay

- modification of messages

- denial of service

I think that it is obvious

Example: *to change the IBAN
code in a bank transfer*

am (or the

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked system

- the **goal**

- four main

- masquerade
- replay
- modification of messages
- denial of service

An **interruption** in an authorized user's access to a computer network, typically one caused with malicious intent

Example: the Mirai botnet

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Economy of mechanism**: the design of security measures should be **as simple as possible** (*i.e. **simpler** to implement and to verify, **fewer** vulnerabilities*)
- **Fail-safe default**: access decisions should be based on **permissions** rather than exclusion (*i.e., the **default** is lack of access*)
- **Complete mediation**: every access should be checked against the **Access Control system** (*see Chapter 4*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Open design**: the design should be **open rather than secret** (e.g., *encryption algorithms*)
- **Separation of privileges**: **multiple privileges** should be required to achieve access to a restricted resource (or to complete some tasks)
- **Least privilege**: every user (or process) should operate **using the least set of privileges** necessary to perform a task (e.g., the sysadmin must **not** surf the Web using the administrator user)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Least common mechanism**: a design should minimize the **functions shared** by different users/entities (*e.g., **sharing state** among different software programs*)
- **Psychological acceptability**: the security mechanisms should not **interfere** unduly with the work of users (*i.e. **user's acceptance** of security mechanisms*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Isolation:**
 - **public access** should be isolated from critical resources (*i.e., no connection between public and critical information*)
 - **users files** should be isolated from one another (except when desired)
 - the **security mechanism** should be isolated (*i.e., preventing access to those mechanisms*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Encapsulation**: similar to **object-oriented programming concepts** (*i.e., hide internal structures*)
- **Modularity**: development of security functions as **separate, protected modules** and use of a **modular architecture** (*for the mechanism design and implementation*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Layering (defense in depth)**: use of **multiple, overlapping** protection approaches (*e.g., multiple firewalls based on different technologies and approaches*)
- **Least astonishment**: a program or interface should always respond in a way that is **least likely to astonish a user** (*e.g., an error window that belong to what running program?*)

Security Mechanism



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- It is (or it should be) **designed to**:
 - **prevent** attackers from violating security policy
 - **detect** attackers' violation of security policy
 - **response** to **mitigate** attack
 - **recover**, continue to function **correctly** even if **attack succeeds**
- No single mechanism is able to support all services:
 - **Example**: *authentication, authorization, availability, confidentiality, integrity, non-repudiation*

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable vulnerabilities** in a system:

- **services listening on the network**

“Open ports”: running processes using network sockets

- an employee (or a subcontractor) with **access to sensitive information**



A “**firewall**” is a software or hardware tool used to **restrict the network access to a system**

abilities in a system:

- **services** **listening on the network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



Its goal is to **permit authorized access** and to **deny unauthorized (i.e., malicious) attempts**

abilities in a system:

- **services** **listening on network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

... but also **Application
Programming Interfaces (APIs),
SQL queries, web forms ...**

abilities in a system:

- **services** that are **protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Network Scanning



NMAP

Exposed attack surface

What is it?

Check it out!

T1

Attack Surface: **categories**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Three main **categories**
 - **network** attack surface (i.e. **network vulnerability**)
 - **software** attack surface (i.e. **software vulnerability**)
 - **human** attack surface (i.e. **social engineering**)
- Attack surface **analysis**
 - **assessing the scale and severity of threats** (i.e. to decide **how to allocate** the available resources)... it is **not easy**...

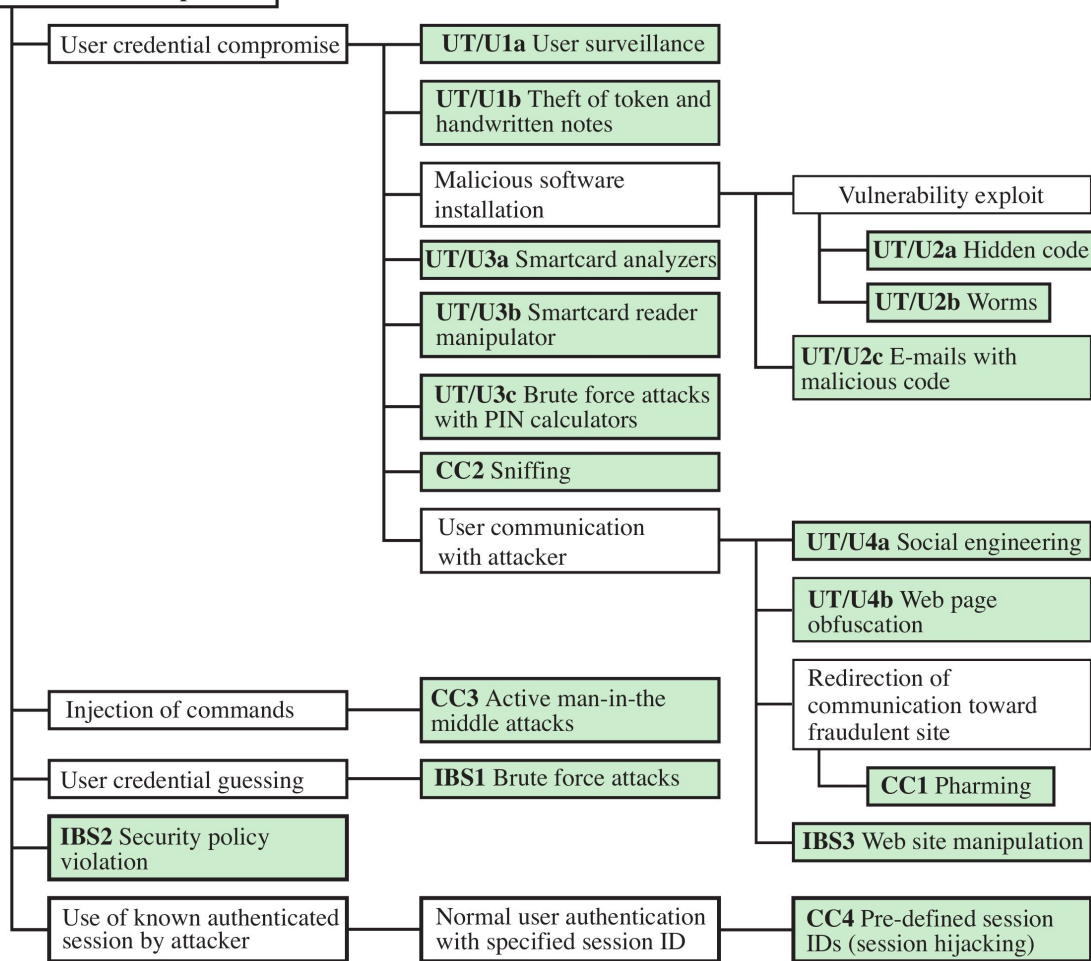
Attack Trees



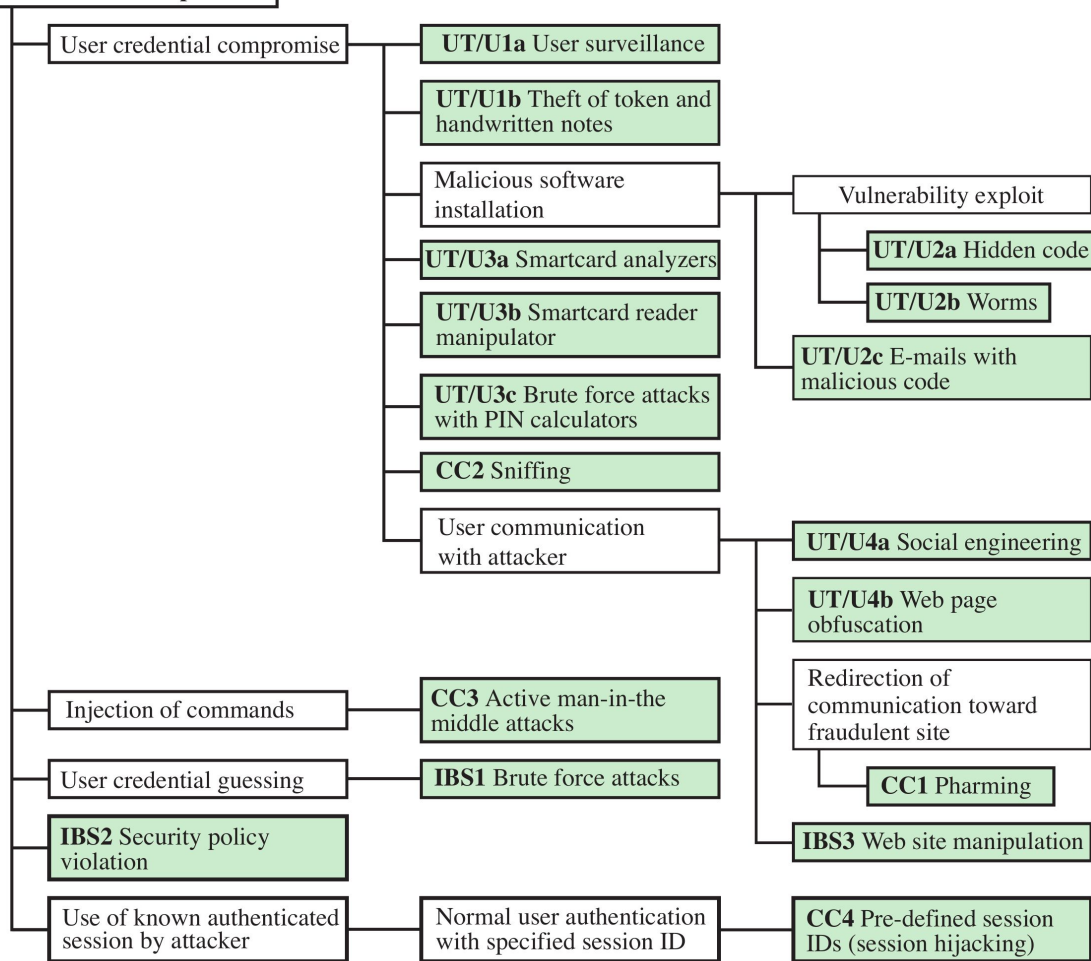
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attack trees** are often used to perform **attack surface analysis**
- An **attack tree** is a **branching, hierarchical** data structure that **represents a set of potential vulnerabilities**
- **Objective:** to effectively exploit the info available on **attack patterns**
(i.e. the methods used to find errors or problems in the systems)
- **Attack trees** can be used by the **security analysts** **to guide design and strengthen countermeasures**

Bank Account Compromise



Bank Account Compromise

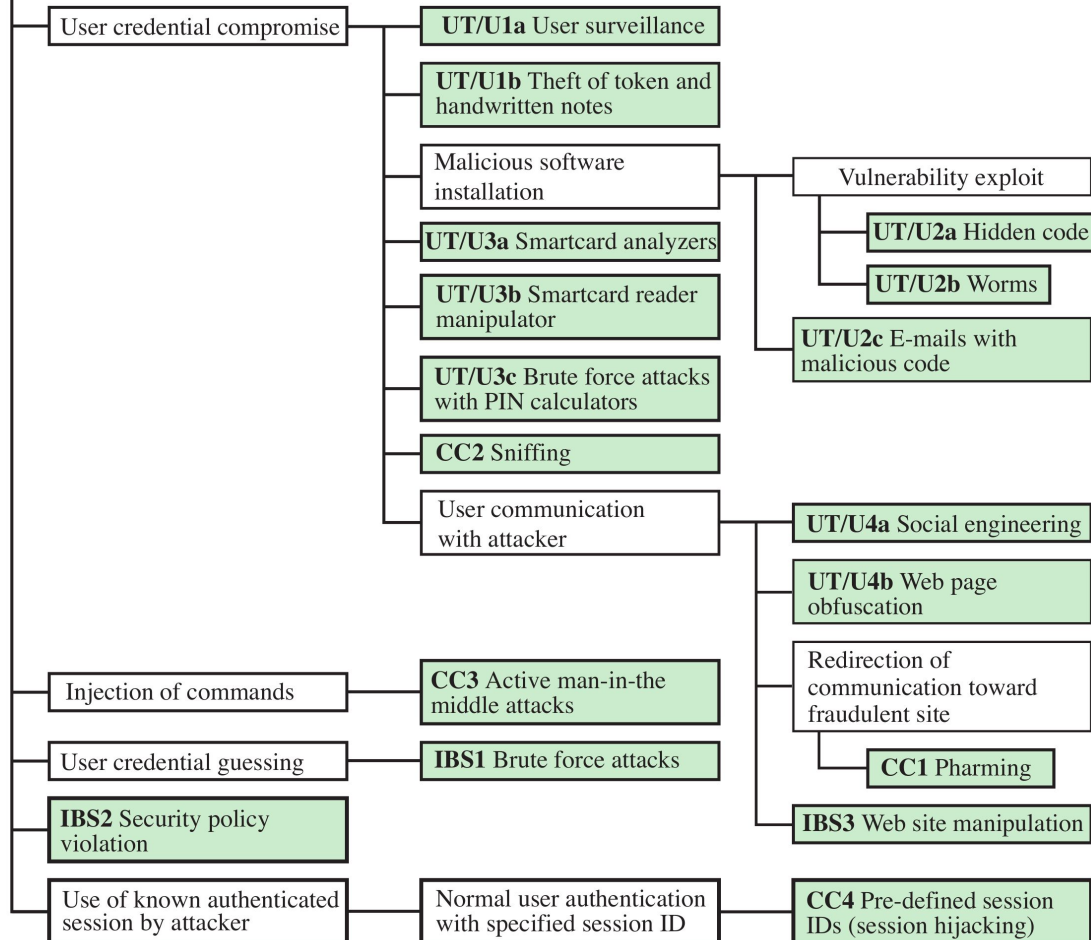


The goal is to compromise
an online bank account



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise



The goal is to compromise
an online bank account

This can be done in many
different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

Malicious software installation

UT/U3a Smartcard analyzers

UT/U3b Smartcard reader manipulator

UT/U3c Brute force attacks with PIN calculators

UT/U3d Sniffing

UT/U3e Communication hijacker

Vulnerability exploit

UT/U2a Hidden code

UT/U2b Worms

UT/U2c E-mails with malicious code

UT/U4a Social engineering

For example:
**compromising the
credentials**

Injection of

User creden

IBS2 Security violation

Use of known authenticated session by attacker

with specified session ID

with specified session IDs (session hijacking)

The goal is to compromise an online bank account

This can be done in many different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

or **guessing** them
(i.e., weak passwords)

Communication
Attacker

UT/U4a Social engineering

UT/U4b Web page obfuscation

Redirection of communication toward fraudulent site

CC1 Pharming

IBS3 Web site manipulation

Injection of command

CC3 Active man-in-the middle attacks

User credential guessing

IBS1 Brute force attacks

IBS2 Security policy violation

Use of known authenticated session by attacker

Normal user authentication with specified session ID

CC4 Pre-defined session IDs (session hijacking)

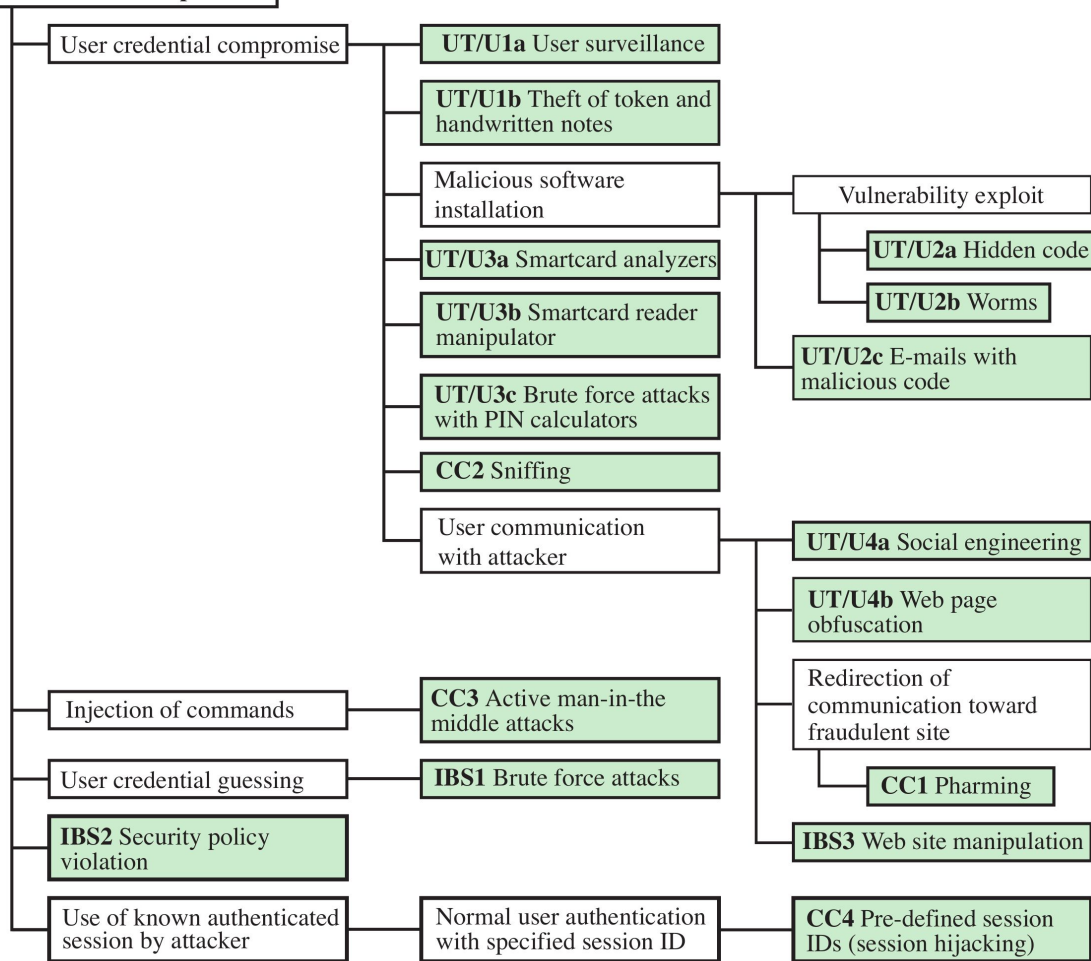
The goal is to compromise an online bank account

This can be done in many different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise





ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

Gabriele D'Angelo

<g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

www.unibo.it

Attributions and Notes



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Most of the slides are from: “**Computer Security: Principles and Practice**”, 4th global edition, W. Stallings and Lawrie Brown
- Some others are from: Dr. **Mehmet H. Gunes** (Department of Computer Science & Engineering - University of Nevada, Reno)
- Some others are from: **Mario Cagalj**, Ph.D. (Faculty of Electrical Engineering, Mechanical Engineering and Naval Architecture (FESB), University of Split)
- Some others are from: Prof. **Hossein Saiedian**, University of Kansas
- The “risk matrix” is from this [blog](#)
- I wish to **thank all of them**, **any errors that remain are my sole responsibility**